

EXERCISE 11

DIGITAL SIGNATURE

PROBLEM 10.1

In this problem we consider some basic aspects of security services.

- (1) In Section 10.1.3 we state that sender (or message) authentication always implies data integrity. Why? Is the opposite true too, i.e., does data integrity imply sender authentication?
- (2) Does confidentiality always guarantee integrity?

Justify all of your answers.

PROBLEM 10.2

A painter comes up with a new business idea: He wants to offer custom paintings from photos. Both the photos and paintings will be transmitted in digital form via the internet. One concern that he has is discretion towards his customers, since potentially embarrassing photos, e.g., nude pictures, might be sent to him. Thus, the photo data should not be accessible to third parties during transmission. The painter needs multiple weeks for the creation of a painting, and hence he wants to ensure that he cannot be fooled by someone who sends in a photo assuming a false name. He also wants to be assured that the painting will definitely be accepted by the customer and that she cannot deny the order.

- (1) Which of the four basic security services are needed for the communication between the customers and the painter. Provide a one-sentence justification for every security service.
- (2) Which cryptographic primitives (e.g., symmetric encryption) can be utilized to achieve the security services? Assume that several megabytes of data have to be transmitted for every photo.

PROBLEM 10.3

In this problem we look at the RSA signature scheme.

- (1) Compute the RSA signature for the message $x = 1234$ and modulus $n = 11111$. Choose e as small as possible.
- (2) What is the benefit of choosing a small public exponent e ? Justify your answer!

PROBLEM 10.4

Compute the RSA signatures for the messages x below with the public key $(n, e) = (2183, 97)$ and the private key $(d) = (409)$. Check your results by verifying the signatures.

- (1) $x = 55$
- (2) $x = 584$

PROBLEM 10.5

Given an RSA signature scheme with the public key $(n = 9797, e = 131)$, which of the following signatures are valid?

- (1) $(x = 123, \text{sig}(x) = 6292)$
- (2) $(x = 4333, \text{sig}(x) = 4768)$
- (3) $(x = 4333, \text{sig}(x) = 1424)$

PROBLEM 10.6

Given an RSA signature scheme with the public key $(n = 9797, e = 131)$, show how Oscar can perform an existential forgery attack by providing an example.

PROBLEM 10.7

In an RSA digital signature scheme, Bob signs messages x_i and sends them together with the signatures s_i and his public key to Alice. Bob's public key is the pair (n, e) ; his private key is d .

Oscar can perform a man-in-the-middle attack, i.e., he can replace Bob's public key with his own during transmission on the channel. His goal is to alter messages and provide these with a digital signature that will check out correctly on Alice's side. Show everything that Oscar has to do for a successful attack.

PROBLEM 10.8

Given is an RSA signature scheme with EMSA-PSS padding as shown in Section 10.2.3. Describe step-by-step the verification process that has to be performed by the receiver of a signature that was EMSA-PSS encoded.

PROBLEM 10.9

In this problem we study the computational efforts required to (i) sign a message and (ii) verify a signature. We look at the schoolbook RSA digital signature algorithm.

- (1) How many multiplications do we need, on average, to perform (i) signing of a message with a general exponent, and (ii) verification of a signature with the short exponent $e = 2^{16} + 1$? Assume that n has $l = \lceil \log_2 n \rceil$ bits. Assume the square-and-multiply algorithm is used for both signing and verification. Derive general expressions with l as a variable.
- (2) Which takes longer, signing or verification?
- (3) We now derive estimates for the speed of actual software implementation. Use the following timing model for multiplication: The computer operates with 32-bit data structures. Hence, each full-length variable, in particular n and x , is represented by an array with $m = \lceil l/32 \rceil$ elements (with x being the base of the exponentiation operation). We assume that one multiplication or squaring of two of these variables modulo n takes m^2 time units (a time unit is the clock period times some constant larger than 1 which depends on the implementation). Note that you never multiply with the exponents d and e . That means the bit length of the exponent does not influence the time it takes to perform an individual modular squaring or multiplication.

How long does it take to compute a signature/verify a signature if the time unit on a certain computer is 100 ns, and n has 1024 bits? How long does it take if n has 2048 bits?

- (4) Smart cards are often used for computing digital signatures. Smart cards with a 32-bit microprocessor are popular in practice. What time unit is required in order to perform one signature generation in 0.5 s if n has (i) 1024 bits and (ii) 2048 bits? Since these processors cannot be clocked at more than, say, 80 MHz, is the required time realistic?

PROBLEM 10.10

We now consider the Elgamal signature scheme. Given are Bob's private key $K_{pr} = d = 67$ and the corresponding public key $K_{pub} = (p, \alpha, \beta) = (97, 23, 15)$.

- (1) Calculate the signature (r, s) and the corresponding verification for a message from Bob to Alice with the following messages x and ephemeral keys k_E :
 - (a) $x = 17$ and $k_E = 31$
 - (b) $x = 17$ and $k_E = 49$
 - (c) $x = 85$ and $k_E = 77$
- (2) You receive two messages x_1 and x_2 with their corresponding signatures (r_i, s_i) that are allegedly from Bob. Verify whether the messages $(x_1, r_1, s_1) = (22, 37, 33)$ and $(x_2, r_2, s_2) = (82, 13, 65)$ actually originate from him.
- (3) Compare the RSA signature scheme with the Elgamal signature scheme. Name some advantages and drawbacks of each?

PROBLEM 10.11

Given is an Elgamal signature scheme with $p = 31$, $\alpha = 3$ and $\beta = 6$. You receive the message $x = 10$ twice with the signatures (r, s) :

- (i) $(17, 5)$
- (ii) $(13, 15)$

- (1) Are both signatures valid?
- (2) How many valid signatures are there for each message x with the specific parameters from above?

PROBLEM 10.12

Given is an Elgamal signature scheme with the public parameters $(p = 97, \alpha = 23, \beta = 15)$. Show how Oscar can perform an existential forgery attack by providing an example of a valid signature.

PROBLEM 10.13

Given is an Elgamal signature scheme with the public parameters p , $\alpha \in \mathbb{Z}_p^*$ and an unknown private key d . Due to an incorrect software implementation, there is the following dependency between two consecutive ephemeral keys:

$$k_{E_{i+1}} = k_{E_i} + 1$$

Assume two consecutive signatures for the plaintexts x_1 and x_2 are given: (r_1, s_1) and (r_2, s_2) . Explain how an attacker is able to calculate the private key with these values.

PROBLEM 10.14

The parameters of a DSA scheme are given by $p = 59$, $q = 29$, $\alpha = 3$, and Bob's private key is $d = 23$. Show the process of signing (by Bob) and verification (by Alice) for the following hashed messages $h(x)$ and ephemeral keys k_E :

- (1) $h(x) = 17$, $k_E = 25$
- (2) $h(x) = 2$, $k_E = 13$
- (3) $h(x) = 21$, $k_E = 8$

PROBLEM 10.15

Show how DSA can be attacked if the same ephemeral key is used to sign two different messages.

PROBLEM 10.16

We consider the ECDSA scheme. The parameters are the curve $E : y^2 \equiv x^3 + 2x + 2 \pmod{17}$, the point $A = (5, 1)$ of order $q = 19$ and Bob's private $d = 10$. Show the process of signing (by Bob) and verification (by Alice) for the following hashed messages $h(x)$ and ephemeral keys k_E :

- (1) $h(x) = 12$, $k_E = 11$
- (2) $h(x) = 4$, $k_E = 13$
- (3) $h(x) = 9$, $k_E = 8$

PROBLEM 10.17

Bob has noticed that somebody can sign messages in his name. Upon inspection of his signature software, he notices that the random number generator always chooses the same ephemeral key for the Elgamal signature scheme. Since his implementation lacks a good TRNG, Bob implements the following countermeasure. He modifies the random number generator such that the new key is computed by multiplying the value of the previous key with 3, i.e.,

$$k_{E(i+1)} = 3 \cdot k_{E(i)}$$

Furthermore, he verifies that the gcd condition holds: $\gcd(k_E, p-1) = 1$. In case the gcd is not 1, Bob multiplies the key again by 3. Describe how an attacker can compute the secret key d if he gets two consecutive messages and signature tuples, each consisting of (x, r, s) .

Hint: In this problem, no specific values for the parameters are given. Your task is to provide a generic solution.